

Subject: Scan Report: <https://www.corsha.com> — 15 findings (completed)

Date: Friday, March 20, 2026 at 9:48:49 AM Eastern Daylight Time

From: SecureStep Scan

To: Reni Nishku



Vulnerability Assessment Report

Security scan results for <https://www.corsha.com>

Scan ID: 074a92368ca3

Completed: 2026-03-20 13:45:40 UTC

Severities: critical, high, medium, low, info

Findings: 15

1. Narrative Assessment

An automated security assessment of <https://www.corsha.com> did not identify critical or high-risk, directly exploitable web application vulnerabilities in the results provided. The findings are primarily informational and configuration-oriented, with the most meaningful security value coming from tightening browser-facing protections and cookie handling. Overall, the immediate risk to the business appears **low**, with opportunities to reduce exposure to common web attack techniques and improve defensive resilience.

From a perimeter and resilience perspective, the site appears to be protected by a **web application firewall (WAF)**. In practical terms, this indicates that inbound traffic is likely being inspected and filtered for suspicious patterns, which can reduce the likelihood that commodity attacks (such as automated scanning and basic injection attempts) reach the application. While a WAF is not a substitute for secure application design, it is a meaningful compensating control that can lower the probability of opportunistic compromise and reduce noise for operational teams.

Several findings relate to **browser-side security controls** that help prevent modern web attacks even when an attacker can influence how a user's browser interacts with the site. The assessment identified **missing HTTP security headers**, which typically means the site is not fully instructing browsers to enforce protective behaviors such as restricting where scripts can load from, preventing the site from being embedded in other pages, and reducing the risk of certain cross-site scripting and clickjacking

scenarios. In business terms, these headers are low-cost controls that reduce the likelihood of account compromise, session abuse, and brand-impacting incidents that can arise from malicious content injection or deceptive user-interface overlays. The severity is best characterized as **low to moderate** depending on the site's functionality (for example, whether it includes authentication, forms, or sensitive user workflows).

The assessment also identified cookies that do not include a **SameSite=Strict** attribute. Practically, this means a user's browser may send certain cookies in more cross-site situations than necessary, which can increase exposure to cross-site request forgery-style abuse in some application designs. The business risk is typically not immediate on its own, but it can become important when combined with authenticated actions or sensitive workflows, where an attacker's goal is to trick a logged-in user's browser into submitting unintended requests. This is generally a **low severity** configuration issue, but it is a worthwhile hardening step because it reduces the attack surface for common web exploitation chains.

On the cryptographic and transport side, the assessment performed **TLS version and certificate discovery** and extracted certificate issuer and DNS names from the certificate. These are primarily informational observations that help confirm the site is using modern encrypted transport and that the certificate is configured to cover the expected hostnames. While no explicit weak protocol or cipher issue was reported in the provided results, maintaining strong TLS configurations matters because it protects customer trust, reduces the risk of downgrade or compatibility-driven weaknesses, and supports compliance expectations for encrypted communications.

Finally, DNS-related discovery identified the presence of **CNAME/SaaS service indicators, IPv6 (AAAA)**, and a **CAA record**. In business terms, these are normal components of modern hosting and certificate governance. The CAA record is a positive control because it restricts which certificate authorities are permitted to issue certificates for the domain, reducing the risk of mis-issuance. IPv6 enablement is also common; however, it should be managed with the same rigor as IPv4 to ensure security controls (WAF/CDN coverage, access controls, and monitoring) apply consistently across both address families.

2. Overall Risk Posture

Overall risk posture: Low. The observed issues are primarily hardening opportunities rather than direct compromise paths, and the presence of a WAF and DNS certificate

governance controls are positive indicators; addressing missing browser security headers and tightening cookie attributes would further reduce exposure to common web attack patterns.

3. Priority Actions

1. Implement a baseline set of HTTP security headers (including Content Security Policy, clickjacking protection, and strict transport guidance) aligned to the site's functionality and risk profile.
2. Update application cookies to use appropriate SameSite settings (prefer Strict where feasible, otherwise Lax) and confirm Secure and HttpOnly are consistently applied for session-related cookies.
3. Validate TLS configuration against current best practices (TLS 1.2+ with strong ciphers, TLS 1.3 where supported) and confirm no legacy protocol support is enabled.
4. Confirm WAF coverage and policy tuning for key application paths, including rate limiting and bot mitigation where appropriate.
5. Review IPv6 exposure to ensure the same protections and monitoring applied to IPv4 (WAF/CDN, logging, and access controls) are enforced for IPv6 endpoints.

4. Findings Summary Table

Category	Finding	Severity	Business Risk	Recommended Action
Infrastructure Security	Web Application Firewall (WAF) detected	Info	Indicates perimeter filtering is in place, which can reduce successful opportunistic attacks, but does not eliminate application-layer risk.	Confirm WAF is actively enforced (not monitor-only), tuned for key routes, and integrated with logging/alerting.
Web Security	Missing HTTP security headers	Low	Reduces browser-enforced protections, increasing exposure to clickjacking and certain script/content injection outcomes that can impact users and brand trust.	Implement a hardened header baseline (e.g., CSP, X-Frame-Options or frame-ancestors, HSTS where appropriate, X-Content-Type-Options, Referrer-Policy) and validate with regression testing.

Web Security	Cookies missing SameSite=Strict	Low	May allow cookies to be sent in more cross-site contexts than necessary, increasing the likelihood of cross-site request abuse for authenticated workflows.	Set SameSite to Strict where feasible (or Lax when compatibility requires), and confirm Secure/HttpOnly on session and sensitive cookies.
Cryptographic	TLS version discovery (protocol posture not flagged as weak in provided results)	Info	Visibility into encryption configuration supports assurance and compliance; weak protocol support (if present) could increase interception or downgrade risk.	Verify TLS 1.2+ only (prefer TLS 1.3), disable legacy protocols, and validate cipher suites against current best practices.
Cryptographic	SSL certificate issuer and SAN (DNS names) enumerated	Info	Primarily informational; helps confirm certificate scope and reduces misconfiguration risk that could cause outages or trust warnings.	Ensure certificate SANs match intended public hostnames and maintain automated renewal/monitoring for expiration.
DNS Security	CAA record present	Info	Positive governance control that reduces the risk of unauthorized certificate issuance and related impersonation scenarios.	Review CAA entries periodically to ensure they reflect approved certificate authorities and operational requirements.
DNS / Third-Party Exposure	CNAME/SaaS service indicator detected	Info	Third-party dependencies can introduce availability and configuration risk if ownership, routing, or DNS records are not tightly managed.	Maintain an inventory of third-party services behind DNS records and implement change control and monitoring for DNS modifications.
Infrastructure	IPv6 (AAAA) record detected	Info	If IPv6 paths are not equally protected, attackers may bypass controls designed primarily around IPv4.	Confirm WAF/CDN, access controls, and logging apply to IPv6 endpoints and that security testing includes IPv6.

Privacy / Tracking Controls	Google FLoC explicitly disabled	Info	Positive privacy posture; reduces exposure to certain cohort-based tracking behaviors and supports user trust expectations.	No action required; retain this control as part of privacy-by-design practices.
Application Discovery	Technology fingerprinting observed (Wappalyzer detection)	Info	Technology identification can help attackers tailor exploits if outdated components exist, though this finding alone does not indicate a vulnerability.	Maintain patch currency for identified platforms and consider reducing unnecessary version disclosure where feasible.

5. Closing Offer

If helpful, we can provide additional materials to make these results easier to share internally or to support remediation planning:

- A board-ready one-page summary of the findings and business impact
- A remediation roadmap with recommended priorities and timelines
- A technical remediation checklist for your IT or engineering team

If you would like, we can also walk through the findings and recommended improvements in a brief 30-minute review. Many of these configuration updates are straightforward to implement and can quickly strengthen the site's security posture.

[Schedule a meeting](#)

This report was generated automatically. Analysis powered by OpenAI.

 This scan may not detect all vulnerabilities. A clean report does not guarantee complete security.